

Lab 02 - SQL Injection Login bypass

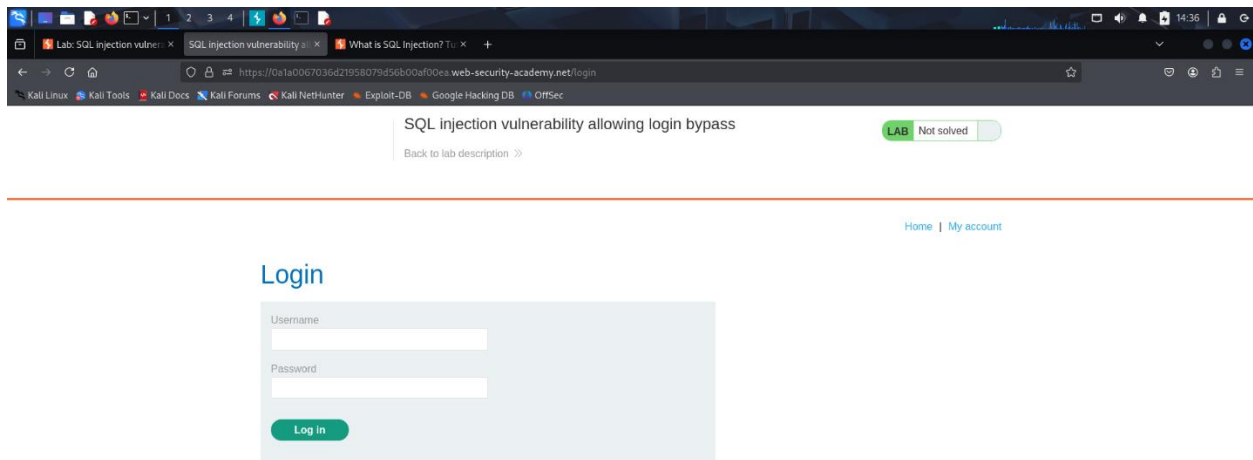


Figure 1 –Normally when you log in, the app checks two things, your username AND your password. The SQL query looks like:

SELECT * FROM users WHERE username = 'administrator' AND password = 'yourpassword'

Both conditions must be true for login to succeed.

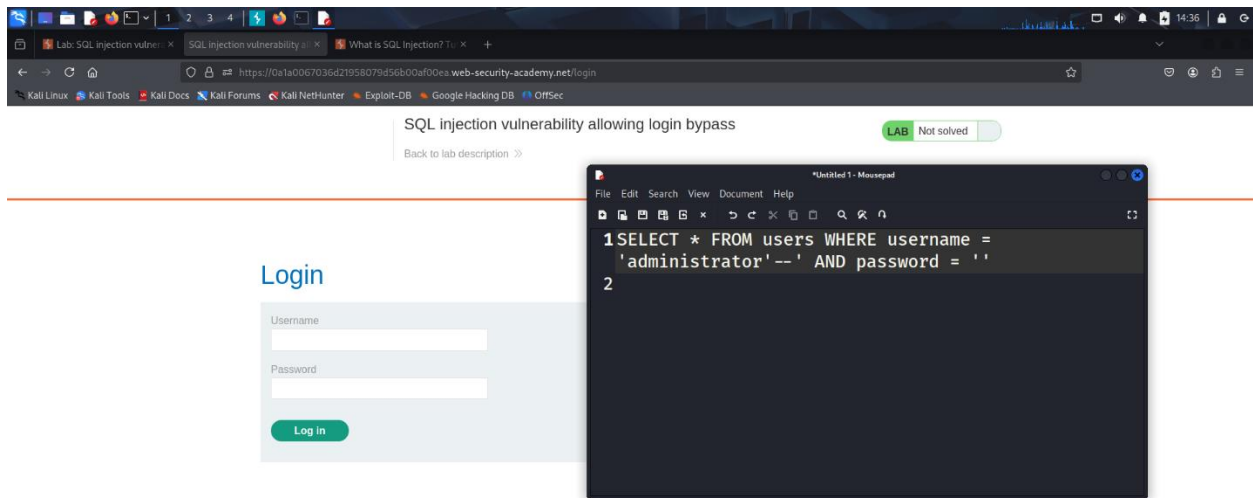


Figure 2 - When you type administrator'-- as the username, the single quote ' closes the username string early. Then -- tells the database “Ignore everything after this.”

So, the query becomes:

SELECT * FROM users WHERE username = 'administrator'--' AND password = 'anything'

The password check is completely commented out. The database only checks the username which exists so it logs you straight in.

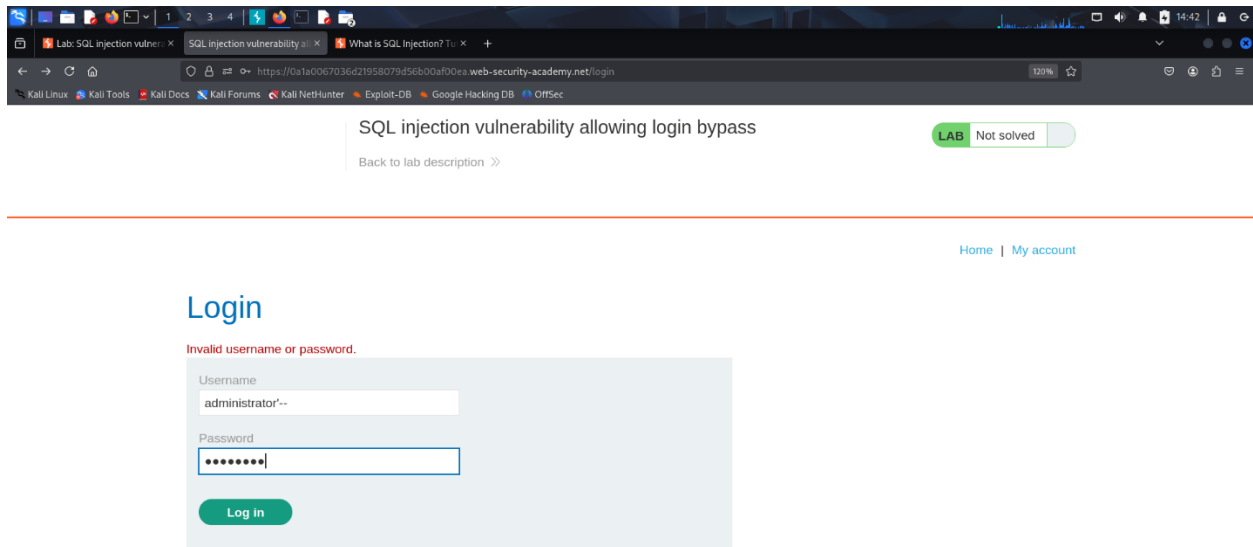


Figure 3 – By default administrator account almost always exists in web apps. It's the highest privilege account which is exactly what an attacker wants.

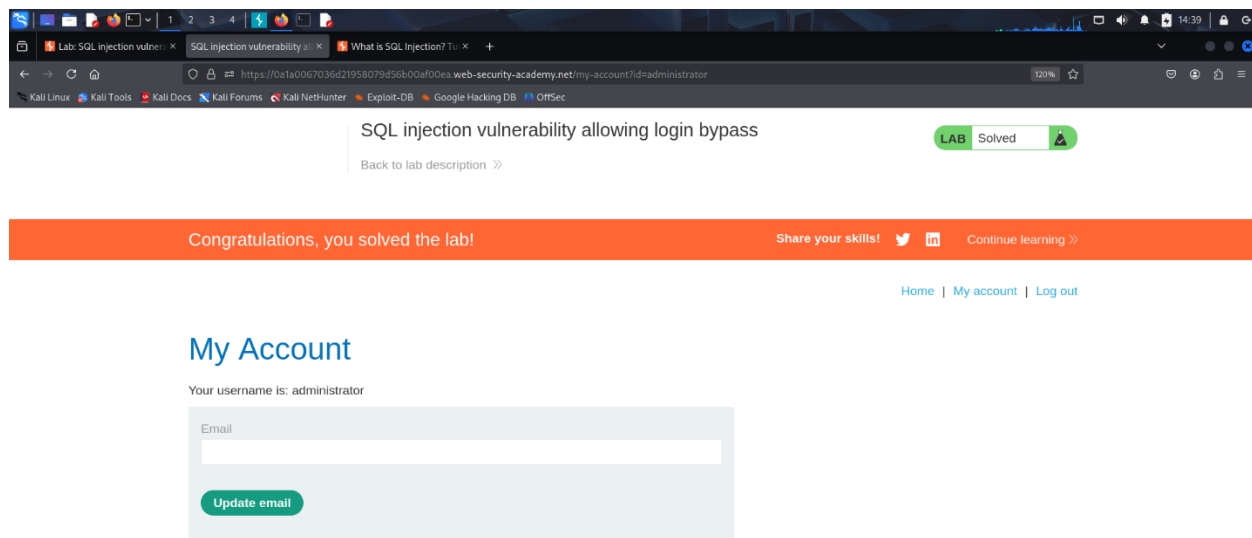


Figure 4 - Successfully logged in as administrator without a valid password